第十五讲 课堂教学实录视频讲稿

> *课程：Java Web应用开发 (Java Web Application Development)*
> *赛道：人工智能赛道*
> *课堂主题：用户认证与权限控制 (Authentication & Authorization)*
> *建议时长：45分钟*
> *授课方式：双语教学（中文讲解 + 英文关键术语）*
> *教学场所：多媒体机房（每人一机）*
> ***AI工具：WebDev助教 / WebSec挑战 / TeamCoach / Code Review Battle***

课前准备清单

录制前确认以下事项全部就绪：

1. **投影系统**：Marp课件已全屏投影，可随时切换到浏览器
2. **WebDev助教后台**：教师仪表盘已登录，学情数据面板可展示
3. **TeamCoach**：本周团队周报已生成，页面已打开备用
4. **课程作业管理系统（问题版）**：Tomcat已启动，可用 `admin/admin123` 和 `tom/tom123` 登录
5. **WebSec挑战平台**：第15讲关卡已配置，实时数据大屏可展示
6. **Code Review Battle平台**：对战已创建，待审查代码已加载
7. **备用截图**：所有AI平台的关键页面截图已保存，防止网络故障
8. **学生分组**：A/B/C三组已提前分好，学生已知分组
9. **摄像机位**：主机位对准教师+投影，辅机位可拍学生区域

阶段一：数据驱动导入（0:00-5:00，5分钟）

[0:00-0:30] 开场问候与课题引入

画面：课件封面页——"用户认证与权限控制 Authentication and Authorization"

教师动作：站在讲台中央，面向学生，自然微笑

教师台词：

> *同学们好！Welcome to Lecture 15. 今天我们的主题是——用户认证与权限控制，英文叫Authentication and Authorization。*
>
> *不过在正式开始之前呢，我想先给大家看一组数据。这组数据，来自于我们课程的AI助教后台。*

学生活动：安静就坐，进入课堂状态

AI工具操作：无

拍摄提示：中景拍摄教师正面，背景可见投影画面。教师说"看一组数据"时，可略微转身指向屏幕。

预计字数：约80字，用时30秒

[0:30-1:30] WebDev助教 · 课前学情数据展示

画面：切换到WebDev助教教师仪表盘——课前学情数据面板（提问频次热力图、TOP 3热点问题、知识薄弱点分析）

教师动作：走到屏幕一侧，侧身面向学生，用手指向屏幕上的数据

教师台词：

> *大家看，这是WebDev助教——我们课程的AI智能体——在课前三天自动采集的数据。*
>
> *全班58人中，有42位同学在课前向智能体提过问题，覆盖率达到72%，这个参与度非常不错。*
>
> *我们看热点问题TOP 3：排名第一的是"Session过期后如何处理"，有23位同学问到了这个问题；第二是"Filter如何判断用户角色"，18人；第三是"Cookie和Session的安全区别"，15人。*

> *（停顿，看向学生）有同学的问题上榜了吗？*
>
> *另外，智能体分析发现一个很普遍的认知偏差——很多同学混淆了 `invalidate()` 和 `removeAttribute()`。这两个方法看起来都能"退出登录"，但效果完全不一样。*
>
> *根据这些数据，我调整了今天的教学重点——强化Session安全管理和角色权限控制。这就是数据驱动的教学决策。*

学生活动：观看数据面板，部分学生会心一笑（发现自己的问题上榜），个别学生小声交流

AI工具操作：【WebDev助教】展示教师仪表盘 → 课前学情数据面板 → 提问频次热力图 → TOP 3热点问题

拍摄提示：画面以屏幕为主，教师在侧面指点；当教师问"有同学上榜了吗"时，切一个学生区域的反应镜头。

预计字数：约200字，用时60秒

[1:30-2:30] TeamCoach · 团队项目周报展示

画面：切换到TeamCoach周报页面——贡献度对比图、团队风险预警

教师动作：保持在屏幕一侧，语气略严肃但不苛责

教师台词：

> *接下来看另一组数据。这是TeamCoach——我们的团队项目AI教练——生成的上周报告。*
>
> *几个需要关注的问题：第3组，Service层目前无人负责，如果继续下去，到集成阶段很可能成为瓶颈。第5组，有同学连续两周只修改了README文件，代码贡献明显不足。*
>
> *（语气转缓和）这些数据不是要批评谁，而是帮助我们尽早发现问题。TeamCoach基于你们Git仓库的真实提交记录做分析，数据是客观的。*
>
> *还有一个值得注意的数据：全班目前的测试覆盖率是——0%。没有任何一个组写了测试代码。今天我们的攻防闯关环节，会让大家深刻体会到"测试"和"验证"的价值。*

学生活动：认真听取周报数据，相关团队成员互相对视，意识到改进需要

AI工具操作：【TeamCoach】展示团队周报页面 → 贡献度对比图 → 风险预警列表

拍摄提示：以屏幕为主，教师指向具体数据点。注意不要给被点名团队的学生特写镜头，保护学生隐私。

预计字数：约180字，用时60秒

[2:30-4:00] 现场演示权限漏洞

画面：切换到浏览器——课程作业管理系统登录页

教师动作：走到教师机前，开始实际操作演示，边操作边讲解

教师台词：

> *好，数据看完了。现在我们来看一个真实的系统。这是我们课程一直在用的作业管理系统。*
>
> *首先，我用管理员账号登录。（输入 admin / admin123，点击登录）*
>
> *大家看，管理员登录后，首页菜单有一个"管理后台"的入口，点进去，可以看到所有用户信息，可以管理课程设置。这是正常的，没有问题。*
>
> *（退出登录）现在，我换一个普通用户。（输入 tom / tom123，点击登录）*
>
> *Tom是一个普通学生用户。但是大家注意看——（指向屏幕）首页菜单上，也出现了"管理后台"的入口！*
>
> *我们点一下试试.....（点击"管理后台"）*
>
> *（停顿两秒，等页面加载）*
>
> *看到了吗？Tom——一个普通学生——成功进入了管理后台！他可以看到所有同学的信息，甚至可以修改课程设置。*

学生活动：观察操作演示，看到普通用户进入后台时，部分学生会发出惊讶的声音

AI工具操作：无（纯系统演示）

拍摄提示：屏幕录制为主，确保每一步操作清晰可见。教师手指点击的画面要拍到。Tom成功进入后台时，可切一个学生惊讶的反应镜头。

预计字数：约200字，用时90秒

[4:00-5:00] 抛出核心问题

画面：课件大字投影——"如果一个普通用户也能进入管理后台，这个系统安全吗？"

教师动作：从教师机旁走回讲台中央，面向全班，双手自然展开

教师台词：

> *（切回课件，投影核心问题）*
>
> *这就是我们今天要解决的核心问题——*
>
> *"如果一个普通用户登录后也能进入管理后台，这个系统安全吗？"*
>
> *很明显，答案是不安全。但问题出在哪？Tom的身份验证通过了——他确实是一个合法用户。那问题到底是什么？*
>
> *（停顿，扫视全班）有同学能回答吗？*
>
> *（等待1-2秒，如有学生举手，请其回答；如无人回答，自行衔接）*
>
> *对，这里有两个概念需要区分：Authentication——认证，回答的是"你是谁"；Authorization——授权，回答的是"你能做什么"。Tom通过了认证，但系统没有做授权检查。能登录，不等于拥有所有权限。*
>
> *今天这45分钟，我们就要彻底解决这个问题。*

学生活动：思考问题，部分学生尝试回答

AI工具操作：无

拍摄提示：教师正面中景，表情认真。问"有同学能回答吗"时切到学生区域。如果有学生回答，给该学生一个镜头。

预计字数：约180字，用时60秒

阶段二：安全攻防闯关（5:00-20:00，15分钟）

[5:00-7:00] WebSec挑战平台 · 规则说明

画面：切换到WebSec挑战平台——第15讲关卡总览页面（5个关卡列表 + 排行榜）

教师动作：站在屏幕旁，用手指逐一指向各关卡

教师台词：

> *好，接下来我们进入今天最刺激的环节——安全攻防闯关！*
>
> *大家看屏幕。这是我们自主研发的WebSec挑战平台。今天第15讲一共有5个安全关卡：*
>
> *（逐一指向）第1关，SQL注入——我们前面讲过PreparedStatement和字符串拼接的区别，这一关考的就是这个。第2关，越权访问——也就是我们刚才看到的那个问题，Filter权限检查缺失。第3关，Session安全——Session固定攻击，这个比较有挑战性。第4关和第5关是课后完成的，分别是XSS跨站脚本和综合BOSS关。*
>
> *今天课堂上，我们完成前3关。*
>
> *规则是这样的——（语气加重）每个人的题目都不一样！AI会为每位同学生成不同的漏洞代码。你需要做三件事：找到漏洞、写出修复代码、提交后平台自动测试。通过了就过关，排行榜实时更新。*
>
> *（笑着说）所以呢，这次不存在"借鉴"同学答案的可能性。*
>
> *大家现在打开平台，用你们的学号登录。给大家8分钟时间完成前3关。计时现在开始！*

学生活动：打开WebSec挑战平台，登录，开始闯关

AI工具操作：【WebSec挑战】展示平台首页 → 关卡列表 → 排行榜。教师演示AI生成漏洞代码的过程（可简要展示一个示例）

拍摄提示：先拍屏幕上的平台界面全景，然后在教师说"计时现在开始"时，切到学生区域，拍学生纷纷打开电脑开始操作的画面。

预计字数：约250字，用时120秒

[7:00-12:00] 学生闯关 + 教师巡视

画面：投影切换到WebSec挑战平台实时数据大屏（各关通过率、平均用时、排行榜实时滚动）

教师动作：离开讲台，在教室中走动巡视，不时停下来看学生屏幕，偶尔低声指导

教师台词：

> *（走到学生中间，观察进展，2分钟后开始自然穿插以下话语）*
>
> *（路过A区学生时）第1关做得很快啊，不错。注意看它生成的SQL语句到底在哪里拼接了变量。*
>
> *（路过B区学生时）遇到困难了？没关系，想想我们刚才看到的那个Tom进后台的例子——问题出在哪一层？Filter有没有检查角色？*
>
> *（路过C区学生时）做得不错。如果你卡住了，可以随时向WebDev助教提问，但注意——智能体给你的是提示，不是答案，最终的修复代码需要你自己写。*
>
> *（走回讲台，看数据大屏）大家看排行榜，已经有同学完成第3关了，速度非常快！*

学生活动：专注在WebSec挑战平台上闯关。分析AI生成的漏洞代码，编写修复方案，提交测试。部分学生遇到困难时向WebDev助教提问。

AI工具操作：【WebSec挑战】学生在平台上闯关；【WebDev助教】部分学生遇到困难时向智能体提问获取提示

拍摄提示：（重要！）这5分钟要拍到以下画面——(1) 学生专注操作电脑的全景/中景；(2) 学生屏幕上WebSec平台的漏洞代码界面特写；(3) 教师在学生中间走动指导的跟拍；(4) 投影上实时数据大屏的排行榜变化。辅机位拍学生，主机位拍数据大屏。

预计字数：约150字（断续说出），用时300秒

[12:00-15:00] 数据大屏分析 + 暂停闯关讲解

画面：投影——WebSec挑战实时数据大屏，重点突出第2关通过率数据

教师动作：回到讲台，面向全班，语气从观察转为决策

教师台词：

> *好，同学们，我们先暂停一下。请大家抬头看屏幕。*
>
> *我看一下实时数据大屏——第1关，SQL注入，通过率92%，平均用时2.1分钟，非常顺利。这说明大家前面学的PreparedStatement掌握得不错。*
>
> *但是，第2关——越权访问——通过率只有40%，平均用时已经4.8分钟了。而且我看到很多同学在这一关反复提交，始终无法通过。*
>
> *这个数据告诉我，第2关的核心知识点——Filter权限检查——是大家的共性薄弱点。所以我决定暂停闯关，花几分钟集中讲解这个最关键的逻辑。*
>
> *（面向镜头自然补充）这就是数据驱动的即时干预——我不是按预设的教学节奏一直往前走，而是根据学生的实际表现来调整教学，在学生最需要的时候讲最关键的内容。*

学生活动：停下手中操作，抬头看屏幕，准备听讲

AI工具操作：【WebSec挑战】展示实时数据大屏 → 各关通过率 → 第2关标红/预警

拍摄提示：先拍数据大屏全景（确保通过率数字清晰），然后切教师正面中景讲解。教师说"数据驱动的即时干预"时，可稍微面向镜头，这是展示教学理念的关键时刻。

预计字数：约200字，用时80秒（含停顿和等待学生安静）

[15:00-18:00] Filter权限检查 · 核心讲解

画面：课件——"Filter权限检查 · 核心讲解"页面，展示RoleBasedAuthFilter完整代码

教师动作：站在讲台前，边指代码边讲解，语速适中

教师台词：

> *好，大家看这段代码。这是解决越权访问问题的核心——RoleBasedAuthFilter。*
>
> *我们刚才看到的那个漏洞代码里，Servlet只检查了一件事：`session != null`并且`session.getAttribute("user") != null`。翻译成人话就是——"你登录了吗？"如果登录了，就放你进去。*
>
> *但问题在于，Tom也登录了！他确实是一个合法用户，只是他的角色不是ADMIN。所以我们需要的不是检查"是否登录"，而是检查"角色是否匹配"。*

> *看这段修复代码：*
>
> ```
> User user = (User) session.getAttribute("user");
> if (user != null && "ADMIN".equals(user.getRole())) {
>  chain.doFilter(req, res);   // ADMIN放行
> } else if (user != null) {
>  response.sendError(403);    // 已登录但非ADMIN → 403 Forbidden
> } else {
>  response.sendRedirect("/login.jsp");  // 未登录 → 重定向
> }
> ```
>
> *三种情况，三种处理方式：管理员放行、普通用户返回403禁止访问、未登录跳转到登录页。*
>
> *这里有一个关键点——为什么用 `"ADMIN".equals(user.getRole())` 而不是 `user.getRole().equals("ADMIN")`？*
>
> *（等一两秒）因为如果 `getRole()` 返回null，后者会抛空指针异常，而前者不会。这是一个防御性编程的好习惯，defensive programming。*
>
> *还有一个重点：这个Filter用 `@WebFilter("/admin/*")` 注解，意思是它只拦截 `/admin/` 路径下的所有请求。这就是Filter在权限控制中的核心作用——统一入口、统一控制。*
>
> *Authentication回答"你是谁"——这是LoginServlet的工作；Authorization回答"你能做什么"——这是Filter的工作。先认证，后授权，顺序不能反。*

学生活动：认真听讲，对照自己闯关中遇到的困难理解代码逻辑

AI工具操作：无（纯教师讲解）

拍摄提示：教师与代码投影同框，确保代码字号足够大、清晰可读。教师指到哪行代码，镜头可适当推近。讲到"三种情况三种处理"时，可用激光笔或手指依次指出。

预计字数：约350字，用时180秒

[18:00-20:00] 继续闯关 + 数据回升

画面：投影保持实时数据大屏

教师动作：让学生继续闯关，教师在教室中走动观察

教师台词：

> *好，现在大家带着刚才的理解，继续挑战第2关和第3关。你们已经知道了Filter权限检查的核心逻辑，试试能不能把它应用到你自己的漏洞代码里。给大家2分钟时间。*
>
> *（2分钟后，看数据大屏）大家看，第2关的通过率已经从40%上升到78%了！讲解之后效果立竿见影。第3关Session安全，通过率也在持续上升。*
>
> *好，时间到。不管你闯到哪一关，接下来的关卡可以课后继续完成。我们现在进入下一个环节。*

学生活动：继续在平台上闯关，应用刚学到的Filter逻辑修复漏洞代码

AI工具操作：【WebSec挑战】学生继续闯关，数据大屏实时更新通过率

拍摄提示：拍摄数据大屏上通过率数字的变化（从40%到78%的对比），同时穿插学生操作画面。

预计字数：约120字，用时120秒

阶段三：AI代码评审对战（20:00-35:00，15分钟）

[20:00-21:00] Code Review Battle · 平台介绍与规则说明

画面：切换到Code Review Battle平台——对战首页

教师动作：回到讲台中央，语气变得兴奋有活力

教师台词：

> *好，同学们！闯关环节大家表现得非常好。接下来我们进入一个更有挑战性的环节——Code Review Battle，代码评审对战！*
>
> *简单来说就是：你们vs AI，看谁能发现更多的安全漏洞！*

> *规则很简单：第1轮，你们各组自己审查代码，找出安全问题——5分钟，不准用任何AI工具。第2轮，我把同一段代码提交给AI，投影展示AI的审查结果——2分钟。第3轮，我们对比——你们找到了什么，AI找到了什么，谁更准、谁更全——8分钟讨论。*
>
> *这不是考试，这是对战！让我们看看人类和AI谁更厉害。*

学生活动：精神振奋，准备对战

AI工具操作：【Code Review Battle】展示对战平台首页，显示规则

拍摄提示：教师充满热情的正面中景。学生对"你们vs AI"表现出兴趣时，可切一个学生反应镜头。

预计字数：约180字，用时60秒

[21:00-22:00] 分组任务与待审查代码展示

画面：课件——待审查代码 `LogoutServlet.java` 全文 + 分组任务表

教师动作：指向屏幕上的代码，逐行简要说明

教师台词：

> *今天的审查对象是 `LogoutServlet.java`——登出功能的Servlet。屏幕上是完整代码。*
>
> *这段代码里已知存在4个安全漏洞，你们能找到几个？AI又能找到几个？*
>
> *三组的审查重点稍有不同：A组——认证组，重点看LoginServlet和LogoutServlet的Session管理是否安全；B组——授权组，重点看RoleBasedAuthFilter的权限过滤是否按角色控制；C组——视图一致性组，重点看index.jsp的菜单显示是否与权限一致。*
>
> *每组的审查报告要包含四项：问题位置、风险说明、对应知识点、修复建议。*
>
> *好，5分钟倒计时开始！*

学生活动：按组开始审查代码，记录发现的问题

AI工具操作：【Code Review Battle】平台显示待审查代码和计时器

拍摄提示：先全屏拍代码（确保每行清晰），然后拍分组任务表。教师说"开始"后，切到学生讨论的画面。

预计字数：约170字，用时60秒

[22:00-27:00] 第1轮 · 人工审查（5分钟）

画面：投影保持显示待审查代码，右下角显示倒计时

教师动作：离开讲台，在三个组之间走动巡视，低声观察和引导

教师台词：

> *（走到A组附近，低声）A组在看什么？Session那一行？对，想想 `removeAttribute` 和 `invalidate` 有什么区别。*
>
> *（走到B组附近，低声）B组找到什么了？Filter的问题？不错，想想它到底检查了什么，应该检查什么。*
>
> *（走到C组附近，低声）C组在讨论菜单？对，想想前端隐藏和后端控制是一回事吗？*
>
> *（走回讲台，大声）还有2分钟！各组确认一下你们的审查报告。记住——问题位置、风险说明、对应知识点、修复建议，四项都要有。*
>
> *（1分钟后）还有1分钟！*
>
> *（计时结束）好，时间到！请各组停笔。*

学生活动：各组围坐讨论，共同审查代码，记录发现的安全问题。不使用任何AI工具。

AI工具操作：无（纯人工审查阶段，严禁使用AI）

拍摄提示：（重要！）这是展示学生活动的核心环节。必须拍到：(1) 各组学生围坐讨论的全景；(2) 学生指着代码讨论的近景；(3) 学生在纸上/电脑上记录审查结果的画面；(4) 教师走动巡视指导的跟拍。辅机位在学生区域拍组内讨论，主机位跟拍教师走动。

预计字数：约150字（断续说出），用时300秒

[27:00-29:00] 第2轮 · AI审查（2分钟）

画面：切换到Code Review Battle平台——AI审查界面，教师将代码提交给AI

教师动作：回到教师机前，操作提交代码给AI，投影展示全过程

教师台词：

> *好，第2轮，轮到AI上场了！*
>
> *我现在把同一段LogoutServlet代码提交给AI进行安全审查。大家注意看AI的审查过程和输出结果。*
>
> *（提交代码，等待AI输出）*
>
> *好，AI出结果了。我们来看看AI发现了什么——*
>
> *第1个问题：`removeAttribute`应改为`invalidate()`，严重程度高。第2个：Filter未检查角色，严重程度高。第3个：JSP菜单未按角色显示，严重程度中。第4个：未设置Cache-Control响应头，严重程度中。第5个：建议登出改用POST方法，严重程度低。*
>
> *AI一共找到了5个问题。你们找到了几个？我们马上来对比。*

学生活动：观看AI审查过程，记录AI发现的问题，与自己组的发现做对比

AI工具操作：【Code Review Battle】教师将代码提交AI → AI实时输出审查报告 → 报告展示在投影上

拍摄提示：全程屏幕录制，确保AI审查过程完整可见。AI输出结果时，教师逐条念出并指向对应内容。注意拍到学生观看AI结果时的表情反应。

预计字数：约180字，用时120秒

[29:00-31:00] 第3轮 · 各组汇报

画面：课件——各组汇报模板（三列对比表：A组/B组/C组）

教师动作：回到讲台中央，主持各组汇报

教师台词：

> *好，现在各组汇报。每组一分钟，说三件事：你们发现了什么问题、对应什么知识点、修复建议是什么。*
>
> *A组先来！*

> ***（A组代表汇报，预计30秒）***

> *好的，A组抓住了LogoutServlet退出不彻底的问题——`removeAttribute`不等于`invalidate`。这是Session生命周期管理的核心知识点。非常好。*
>
> *B组！*

> ***（B组代表汇报，预计30秒）***

> *B组发现Filter只检查了是否登录，没有检查角色。这就是我们前面讲的Authorization的核心——光认证不够，还要授权。*
>
> *C组！*

> ***（C组代表汇报，预计30秒）***

> *C组发现了一个很容易被忽略的问题——登录后不管什么角色，首页都显示"管理后台"入口。前端隐藏按钮不等于安全控制。好，三组总共发现了3个关键问题。*

学生活动：各组代表站起来汇报，其他学生认真听取

AI工具操作：【Code Review Battle】教师在平台上记录各组发现

拍摄提示：拍汇报学生的正面中近景（站立发言），然后切教师点评的画面。三组轮流拍。

预计字数：约200字（教师部分），用时120秒

[31:00-34:00] 人 vs AI · 对比分析与辩论

画面：课件——"AI审查结果展示"页面 + "人 vs AI 对比表"

教师动作：站在屏幕旁，逐一对比，引导讨论

教师台词：

> *好，现在我们来做最关键的对比。AI找到了5个问题，你们找到了3个。看起来AI赢了？*
>
> *但我们仔细看——（指向对比表）*
>
> *前三个问题：`removeAttribute`应改为`invalidate`——A组发现了。Filter未检查角色——B组发现了。JSP菜单未按角色显示——C组也发现了。这三个关键漏洞，你们全部命中！*
>
> *第4个问题：未设置Cache-Control响应头。这个你们漏掉了。AI说的对——如果用户退出登录后，浏览器缓存了之前的页面，别人只需要点"后退"按钮，就可能看到敏感信息。这是一个真实的安全风险，确实需要在响应头里加上`Cache-Control: no-cache, no-store`。AI帮我们发现了盲区，这说明AI在覆盖面上确实有优势。*
>
> *但是！第5个问题——（语气转变）AI建议我们把登出从GET方法改成POST方法。*
>
> *（面向学生）大家想想，在我们这个系统的设计中，GET登出有什么问题吗？*
>
> *（等学生思考和回答）*
>
> *实际上，在我们当前的系统设计中，GET方式登出是完全合理的。我们没有做CSRF防护的需求，用户点击"退出"链接直接登出，这是最符合用户直觉的设计。AI给出这个建议，是因为它按照"最佳安全实践"的通用标准来检查，但它不了解我们系统的具体设计意图和使用场景。*
>
> *所以这是一个AI误报——false positive。*

学生活动：跟随教师分析，思考AI建议的合理性，参与讨论

AI工具操作：【Code Review Battle】展示人机对比评分面板

拍摄提示：教师指着对比表讲解的中景。讲到"AI帮我们发现了盲区"时语气肯定，讲到"AI误报"时语气要自信坚定。可在关键对比时推近对比表的特写。

预计字数：约350字，用时180秒

[34:00-35:00] 人机协同结论

画面：课件——"人 vs AI 对比与结论"页面

教师动作：走到讲台中央，总结性发言

教师台词：

> *我们来总结一下这场对战的结果。*
>
> *（指向投影）学生发现了3个问题，零误报；AI发现了5个问题，但其中有1个误报。关键漏洞命中率，你们是75%，AI是100%。看起来AI更全面，但你们更精准。*
>
> *更重要的是——AI在业务理解上得分只有两颗星，而你们有四颗星。因为你们懂这个系统的设计意图，AI不懂。*
>
> *这场对战的核心结论就一句话：**人机协同大于单独任何一方**。AI覆盖面广但缺乏业务判断，人理解上下文但可能遗漏细节。最佳模式是——AI先扫描，人做最终判断。*
>
> *记住这句话，这不仅是今天这节课的结论，也是你们未来做开发时使用AI的基本原则。*

学生活动：记录核心结论

AI工具操作：【Code Review Battle】展示最终评分汇总

拍摄提示：教师正面中景，表情认真，语气有力。这是阶段三的总结性时刻，镜头稳定，不要切换。

预计字数：约200字，用时60秒

阶段四：修复与验证（35:00-42:00，7分钟）

[35:00-36:00] 修复环节导入

画面：课件——"第五部分：修复与验证"标题页

教师动作：从对战模式自然过渡到实践模式，走到教师机前准备演示

教师台词：

> *好，闯关做了，评审做了，漏洞我们都找到了。但光发现问题还不够，关键是要能修复并验证。*

> *接下来，我在投影上带大家一起修复三个核心问题，然后你们在自己机器上同步操作。*
>
> *遇到不理解的地方，随时可以向WebDev助教提问——智能体24小时在线，基于我们课程知识库回答，不是泛泛的通用答案。*

学生活动：打开IDE，准备同步修改代码

AI工具操作：【WebDev助教】提醒学生可随时提问

拍摄提示：过渡镜头，教师走向教师机的侧面跟拍。

预计字数：约100字，用时60秒

[36:00-39:00] 教师带领修复三处关键代码

画面：IDE界面——分别打开三个文件进行修复

教师动作：在教师机上操作代码修改，边改边讲解

教师台词：

> ***修复1：RoleBasedAuthFilter***
>
> *首先，打开 `RoleBasedAuthFilter.java`。现在的代码只检查了 `isLoggedIn` ——"是否登录"。我们要改成检查 `user.getRole()`——"角色是否为ADMIN"。*
>
> *（边改边说）把这一行改掉.....`User user = (User) session.getAttribute("user");`.....然后判断 `"ADMIN".equals(user.getRole())`.....ADMIN放行，非ADMIN返回403，未登录重定向到登录页。*
>
> *这就是从Authentication-only升级到Authorization的关键一步。*
>
> ***修复2：index.jsp***
>
> *第二个文件，`index.jsp`。现在的菜单代码是——只要登录了就显示"管理后台"入口。我们要改成按角色条件显示。*
>
> *（边改边说）加上 `<c:if test="${sessionScope.user.role == 'ADMIN'}">`.....只有当用户角色是ADMIN时，才渲染这个管理后台的链接。*

> *但要记住——前端隐藏菜单只是用户体验优化，真正的安全边界在后端Filter。这两层防护必须同时存在，缺一不可。*
>
> ***修复3：LogoutServlet***
>
> *第三个文件，`LogoutServlet.java`。把 `session.removeAttribute("user")` 改成 `session.invalidate()`。*
>
> *（边改边说）`removeAttribute` 只删除了一个属性，Session对象本身还活着，里面可能还有其他属性残留。而 `invalidate()` 是彻底销毁整个Session，所有属性一并清除，服务器端也不再维持这个会话。*
>
> *一个是"擦掉名牌"，一个是"销毁通行证"。效果完全不同。*

学生活动：在自己的IDE中同步修改代码。遇到问题的学生向WebDev助教提问。

AI工具操作：【WebDev助教】部分学生在修复过程中向智能体提问获取知识点解答

拍摄提示：屏幕录制为主，确保代码修改过程完整清晰。每个修复前后做简要的画面停顿，让观看者看清改了什么。穿插拍摄学生同步操作的画面（1-2个镜头）。

预计字数：约350字，用时180秒

[39:00-42:00] 运行测试清单 · 验证修复

画面：浏览器——修复后的系统 + 课件——最小测试清单（5项测试）

教师动作：在教师机上逐项执行测试，投影展示每一步操作和结果

教师台词：

> *代码改完了，但改完不等于改对了。我们必须验证。*
>
> *屏幕上是最小测试清单，5个测试场景，我们逐项过。*
>
> *T1：未登录直接访问 `/admin/panel`。（在浏览器中输入URL，按回车）看——重定向到了登录页。通过！*
>
> *T2：用tom/tom123登录，然后访问 `/admin/panel`。（登录，访问）看——返回了403 Forbidden。普通用户被拒绝了。通过！*

> *T3：用admin/admin123登录，访问 `/admin/panel`。（登录，访问）看——正常进入管理后台。管理员权限正常。通过！*
>
> *T4：管理员退出后再访问 `/admin/panel`。（点击退出，再次访问）看——重定向到登录页，Session已经被彻底销毁了。通过！*
>
> *T5：菜单一致性。tom登录后看首页菜单——（登录tom，看首页）没有"管理后台"入口了！admin登录后看——（登录admin，看首页）有"管理后台"入口。菜单显示与角色一致。通过！*
>
> *5项测试全部通过！系统从"能登录"变成了"能安全控制访问"。*
>
> *现在请大家在自己机器上也执行这5项测试，确认你的修复是正确的。给大家1分钟时间。*

学生活动：在自己机器上运行修复后的系统，按测试清单逐项验证

AI工具操作：无（纯系统验证）

拍摄提示：（重要！）每项测试的操作和结果都要清晰拍到。建议屏幕录制+教师画外音。T2返回403和T5菜单对比是最关键的两个画面，确保停留足够时间。最后拍学生在自己机器上验证的画面。

预计字数：约280字，用时180秒

阶段五：总结与反思（42:00-45:00，3分钟）

[42:00-43:00] 本节课数据回顾

画面：课件——"本节课数据回顾"页面（攻防闯关数据 + 评审对战数据 + WebDev助教数据）

教师动作：回到讲台中央，语气从实操转为反思总结

教师台词：

> *好，修复验证完成。我们来回顾一下今天这节课产生的数据。*

> *攻防闯关：第1关SQL注入通过率92%，第2关越权访问从最初的40%上升到了讲解后的78%，第3关Session安全从12%上升到65%。大家看，数据清楚地反映了——哪里薄弱，讲解后效果如何，一目了然。*
>
> *评审对战：你们三组合计发现了3个关键漏洞，AI发现了5个但包含1个误报。人机协同后，总计确认了4个真实漏洞加1个AI独有的有效发现。*
>
> *WebDev助教的数据：课堂期间有12位同学实时向智能体提问，最热门的问题是"Filter和Servlet的区别"。*
>
> *这些数据会作为过程性评价的一部分，记录在你们每个人的学习档案中。*

学生活动：回顾自己的表现，查看自己在排行榜和评审对战中的成绩

AI工具操作：【全部五维工具】展示各平台的汇总数据

拍摄提示：以课件数据展示为主，教师侧面点评。数据页面要停留足够时间让观看者看清。

预计字数：约200字，用时60秒

[43:00-44:00] 三个核心收获 + 课程思政

画面：课件——"三个核心收获"页面 → "课程思政：制度与秩序"页面 → "AI伦理反思"页面

教师动作：站在讲台中央，面向全班，语气沉稳有力

教师台词：

> *今天这节课，我希望大家记住三件事。*
>
> *第一——认证回答"你是谁"，授权回答"你能做什么"。Authentication不等于Authorization，登录成功不等于拥有所有权限。*
>
> *第二——RBAC加Filter，是后端权限控制的基本骨架。Filter是安全的第一道防线，前端隐藏加后端控制，才是完整方案。*
>
> *第三——人机协同大于单独任何一方。今天的评审对战证明了——AI帮我们发现了Cache-Control问题，但也产生了1个误报；WebSec闯关让每个人都亲手修复了漏洞。批判性判断，永远大于盲目采纳。*

> *（自然过渡到思政）说到权限控制，RBAC的本质其实就是"制度先行、权责明晰"。每个系统——不管是技术系统还是社会系统——都需要规则和边界。我们今天写的每一行权限控制代码，都在守护用户的隐私和权益。这是技术人员的职业责任，也是依法治网的基本要求。*
>
> *同样的道理也适用于AI——AI是强大的助手，但不是裁判。技术决策的最终责任在人。这既是技术原则，也是职业伦理。*

学生活动：认真听讲，记录核心要点

AI工具操作：无

拍摄提示：教师正面中近景，表情认真诚恳。讲三个收获时可配合手势（比"一、二、三"），讲思政部分时语气要自然不生硬，不要有"念稿"的感觉。

预计字数：约280字，用时60秒

[44:00-45:00] 课后任务布置 + 结课

画面：课件——"课后任务"页面

教师动作：走到讲台前方，语气轻松亲切

教师台词：

> *最后是课后任务。*
>
> *第一，完成WebSec挑战平台的第4关和第5关——XSS跨站脚本和综合BOSS关。排行榜一直开放，看谁能拿到第一名。*
>
> *第二，在你们的团队项目中实现权限控制模块——登录、登出、RBAC。TeamCoach会继续追踪每个人的贡献度，下周课前我会再展示周报。*
>
> *第三，有任何疑问，随时向WebDev助教提问，它24小时在线。*
>
> *第四，也是最重要的——写一份AI使用反思。这是必做作业。三个问题：AI在攻防闯关中给你的提示有帮助吗？你怎么判断是否采纳？Code Review Battle中AI的误报说明了什么？在你未来的开发工作中，AI代码审查应该扮演什么角色？*
>
> *（停顿，微笑）今天的课就到这里。希望大家以后做系统，不只追求"能运行"，更要追求"可验证、可控制、可信赖"。*

> *下课！Thank you, class!*

学生活动：记录课后任务，部分学生开始收拾物品

AI工具操作：无

拍摄提示：教师正面全景，学生开始收拾物品时可拍一个自然结束的氛围镜头。最后一句"Thank you, class"时教师可微微鞠躬，这是结课的标志性画面。

预计字数：约220字，用时60秒

附录A：全课时间轴总览

时间段	阶段	核心内容	AI工具	教师台词字数
0:00-0:30	开场	课题引入	—	~80
0:30-1:30	导入	WebDev助教学情数据	WebDev助教	~200
1:30-2:30	导入	TeamCoach周报	TeamCoach	~180
2:30-4:00	导入	权限漏洞演示	—	~200
4:00-5:00	导入	核心问题提出	—	~180
5:00-7:00	闯关	WebSec平台规则	WebSec挑战	~250
7:00-12:00	闯关	学生闯关+巡视	WebSec挑战+WebDev助教	~150
12:00-15:00	闯关	数据驱动干预	WebSec挑战	~200
15:00-18:00	闯关	Filter核心讲解	—	~350
18:00-20:00	闯关	继续闯关+数据回升	WebSec挑战	~120
20:00-21:00	对战	Battle规则说明	Code Review Battle	~180
21:00-22:00	对战	分组+代码展示	Code Review Battle	~170
22:00-27:00	对战	人工审查(5min)	—	~150
27:00-29:00	对战	AI审查(2min)	Code Review Battle	~180
29:00-31:00	对战	各组汇报	Code Review Battle	~200
31:00-34:00	对战	人vs AI对比辩论	Code Review Battle	~350
34:00-35:00	对战	人机协同结论	Code Review Battle	~200
35:00-36:00	修复	修复导入	WebDev助教	~100
36:00-39:00	修复	三处代码修复	WebDev助教	~350
39:00-42:00	修复	测试验证	—	~280

时间段	阶段	核心内容	AI工具	教师台词字数
42:00-43:00	总结	数据回顾	全部五维工具	~200
43:00-44:00	总结	三个收获+思政	—	~280
44:00-45:00	总结	课后任务+结课	—	~220

教师台词总字数：约 4,670字
平均语速：约 104字/分钟（自然口语语速，含停顿和互动时间）

附录B：AI工具使用时间线

AI工具	使用时间点	使用方式	可见证据
WebDev助教	0:30-1:30	教师展示课前学情数据面板	投影上的热力图、TOP 3问题列表
TeamCoach	1:30-2:30	教师展示团队周报	投影上的贡献度对比图、风险预警
WebSec挑战	5:00-20:00	学生闯关+实时数据大屏+教师干预	平台闯关界面、排行榜、通过率数据
WebDev助教	7:00-12:00	学生闯关中遇困难向智能体提问	学生屏幕上的智能体对话界面
Code Review Battle	20:00-35:00	人机对战：人工审查→AI审查→对比辩论	平台对战界面、AI审查报告、评分面板
WebDev助教	36:00-39:00	学生修复代码时向智能体提问	学生屏幕上的智能体回答
全部五维工具	42:00-43:00	教师展示各平台汇总数据	投影上的综合数据面板

附录C：拍摄关键画面清单

以下画面对于人工智能赛道评审至关重要，必须拍到：

1. **[0:30]** WebDev助教后台学情数据面板（投影）
2. **[1:30]** TeamCoach团队周报页面（投影）
3. **[2:30-4:00]** Tom以普通用户身份进入管理后台的完整演示
4. **[5:00-7:00]** WebSec挑战平台关卡总览+AI生成漏洞代码过程

5. **[7:00-12:00]** 学生在电脑上闯关的画面（至少3个不同学生的镜头）
6. **[12:00]** 实时数据大屏显示"第2关通过率40%"
7. **[15:00-18:00]** 教师讲解Filter代码（教师与代码同框）
8. **[18:00-20:00]** 数据大屏显示"通过率从40%升至78%"
9. **[22:00-27:00]** 学生分组讨论审查代码的画面（至少2组）
10. **[27:00-29:00]** AI审查代码的完整过程（投影）
11. **[29:00-31:00]** 学生代表站立汇报的画面
12. **[31:00-34:00]** 人 vs AI对比表（投影）
13. **[36:00-39:00]** 教师修改代码的IDE画面
14. **[39:00-42:00]** 5项测试全部通过的完整演示
15. **[42:00-43:00]** 各平台汇总数据展示

附录D：课件页面切换索引

按时间顺序列出应投影的课件页面，方便录制时翻页：

时间	课件页面/切换目标
0:00	Slide 1: 封面 "用户认证与权限控制"
0:30	切换到浏览器: WebDev助教教师仪表盘
1:30	切换到浏览器: TeamCoach周报页面
2:30	切换到浏览器: 课程作业管理系统登录页
4:00	Slide: 核心问题大字 "如果一个普通用户也能进入管理后台，这个系统安全吗？"
5:00	切换到浏览器: WebSec挑战平台首页
7:00	切换到WebSec实时数据大屏
12:00	数据大屏保持（教师指向通过率数据）
15:00	Slide: "Filter权限检查 · 核心讲解" (RoleBasedAuthFilter代码)
18:00	切回WebSec实时数据大屏
20:00	切换到浏览器: Code Review Battle平台首页
21:00	Slide: 待审查代码 LogoutServlet.java + 分组任务
22:00	保持代码展示（学生审查中）
27:00	切换到浏览器: Code Review Battle AI审查界面
29:00	Slide: 各组汇报表

时间	课件页面/切换目标
31:00	Slide: AI审查结果 → 人 vs AI对比表 → 结论
35:00	Slide: "第五部分：修复与验证" 标题页
36:00	切换到IDE: 修复代码
39:00	切换到浏览器: 运行测试清单
42:00	Slide: "本节课数据回顾"
43:00	Slide: "三个核心收获" → "课程思政"
44:00	Slide: "课后任务"
45:00	Slide: 结束页 "感谢聆听"

附录E：应急预案

可能的问题	解决方案
WebSec挑战平台无法访问	用事先保存的平台截图替代，教师口述闯关流程
Code Review Battle平台故障	用课件中的代码截图，教师手动引导评审流程
WebDev助教响应缓慢	用事先截取的学情数据截图展示
学生机器无法运行项目	教师机演示为主，学生在自己机器上跟做修复
AI审查输出异常	用事先保存的AI审查结果截图替代
录制设备故障	备用手机录制，至少保证音频完整

附录F：教师备忘

1. **语速控制**：每分钟100-110字，留出停顿和互动时间。不要赶进度。
2. **自然过渡**：各阶段之间不要有"下面进入第X环节"这种生硬过渡，用问题或数据自然衔接。
3. **眼神交流**：不要一直看屏幕，经常看向学生。提问时扫视全班。
4. **AI工具操作**：每次打开AI平台时，稍作停顿让镜头捕捉到工具界面。
5. **学生互动**：不要所有问答都自问自答，至少让3-5位学生发言。
6. **数据驱动**：每次展示数据后都要说明"这个数据告诉我什么/我据此做了什么决策"，体现数据驱动教学。
7. **双语要求**：关键术语第一次出现时给出中英文对照，后续可只说英文或只说中文。核心术语包括：Authentication、Authorization、Session、RBAC、Filter、Invalidate、Cache-Control。

8. **课程思政**：思政部分要自然融入总结，不要单独拎出来说"下面是思政环节"，这样会很生硬。